



网络安全技术及应用

(第5版. 微课版. 新形态)

贾铁军 何道敬 罗宜元 主编
古乐声 王威 张书台 副主编
王坚 陈国秦 参编



机械工业出版社
CHINA MACHINE PRESS

第3章 网络安全体系及管理

回顾

应用层	应用层安全协议（如S/MIME、SHTTP、SNMPv3）				第三方公证（如Kerberos）数字签名	入侵检测（IDS）漏洞扫描 审计、日志 响应、恢复	安全服务管理	系统安全管理
	用户身份认证	授权与代理服务 器防火墙如CA.						
传输层	传输层安全协议（如SSL/TLS、PCT、SSH、SOCKS）							
	电路级防火							
网络层（IP）	网络层安全协议（如IPSec）							
	数据源认证IPSec-AH	包过滤 防火墙	如 VPN					
网络接口层	相邻节点间的认证（如MS-CHAP）	子网划分、VLAN、物理隔绝	MDC MAC	点对点加密（MS-MPPE）				
	认证	访问控制	数据完整性	数据机密性	抗抵赖	可控性	可审计性	可用性

回顾

管 理 安 全	应用安全	运 行 安 全
	网络系统安全	
	操作系统安全	
	实体安全	
信息安全法律法规		

第3章 网络安全体系及管理

1

3.1 网络安全的体系结构

2

3.2 网络安全相关法律法规

3

3.3 网络安全评估准则和方法

4

***3.4 网络安全管理原则及制度**

5

3.5 本章小结

6

3.6 实验3 统一威胁管理UTM 应用



教学目标

📖 教学目标

教学重点：网络安全体系、法律、评估准则和方法，管理规范、过程和制度

重点

教学难点：网络安全评估准则和方法，管理规范、原则和制度，网络安全规划

教学关键：网络安全体系、法律、评估准则和方法，安全管理规范和制度

关键

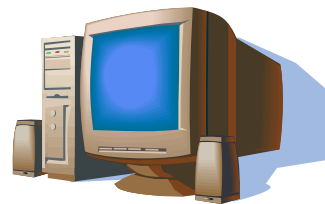
教学目标：理解网络安全战略意义，掌握网络安全体系、法律、评估准则和方法，理解网络安全管理规范、过程、原则和制度，了解网络安全规划的主要内容和原则，掌握网络安全“统一威胁管理UTM”实验。



3.1 网络安全的体系结构

案例3-1

世界各国高度重视网络安全。习近平总书记在2014年的会议讲话中强调：没有网络安全就没有国家安全，就没有经济社会稳定运行，广大人民群众利益也难以得到保障。近几年来，各国不断加强网络安全顶层设计。欧盟在2020年底发布《欧盟数字十年网络安全战略》，打响“数字主权”保卫战；美国在2021 年发布了《改善国家网络安全行政令》，致力于加强网络空间安全能力；日本在2022 年初发布了最新的《网络安全战略》，强化网络空间安全的战略指导。



3.1 网络安全的体系结构

3.1.1 网络空间安全学科知识体系

1. 国际网络空间安全学科知识体系

在国际计算机协会计算机科学教育分会ACM SIGCSE 2018会议上正式发布的网络空间安全学科知识体系（CSEC），主要包含8大知识领域。

国际网络空间安全学科知识体系分为四个层面，第1层数据及软件安全是核心和关键,主要包括软件安全、数据安全和组件安全,第2-3层包括连接安全和系统安全,第4层包括人员安全、社会安全和组织安全.网络系统及管理安全是重要基础和保障,需要从分析、研发、测试和应用等方面建立系统的安全性,通过技术、人员、数据和过程等方面做好全方位的安全防范,利用法律、政策、伦理、人为因素和风险管理等保障系统安全运行,软件安全、组件安全和连接安全是系统安全的重要支撑。

- 1) 人员安全。
- 2) 社会安全
- 3) 组织安全
- 4) 系统安全
- 5) 连接安全
- 6) 软件安全
- 7) 数据安全
- 8) 组件安全

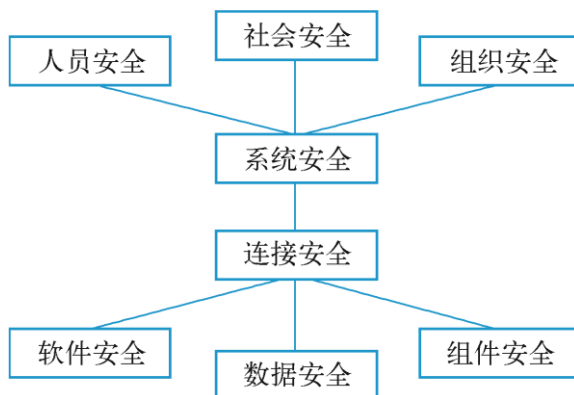
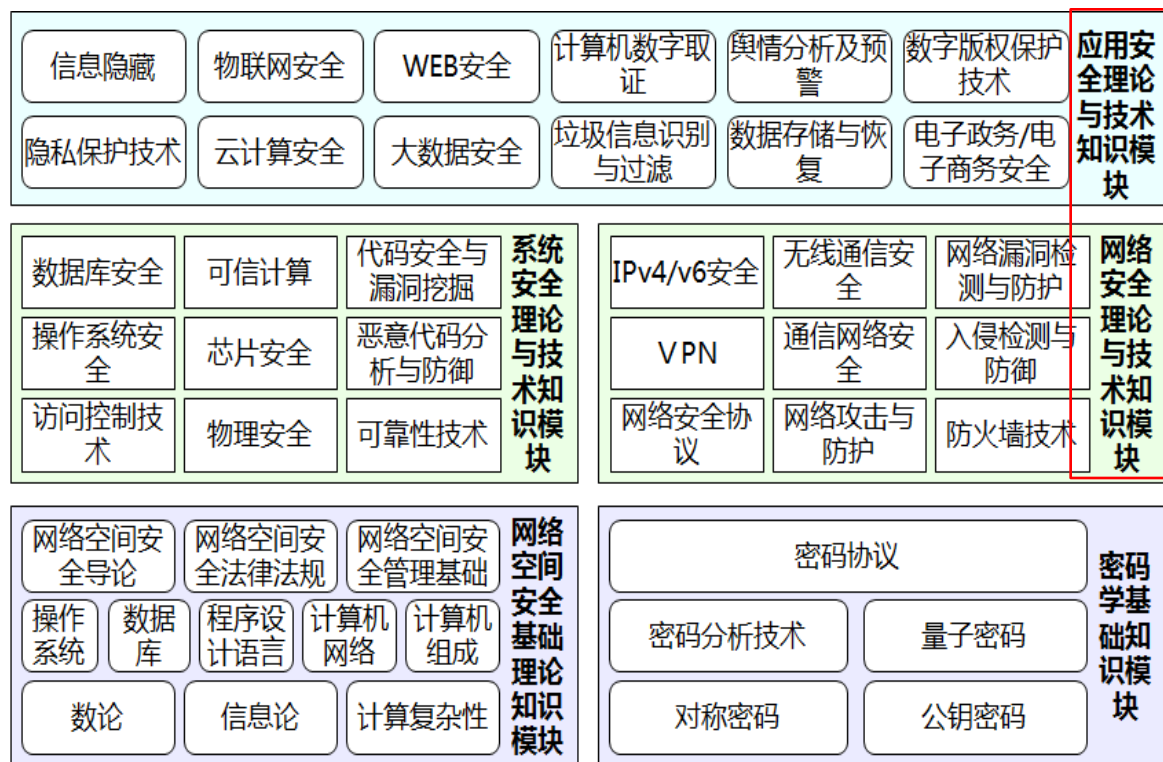


图3-1 网络空间安全学科知识体系

3.1 网络安全的体系结构

2. 国内网络空间安全学科知识体系

教育部信息安全教学指导委员会副主任委员、上海交通大学网络空间安全学院院长**李建华教授、博导**，**2018**年在“**第十二届网络空间安全学科专业建设与人才培养研讨会**”上，所作的“**新工科背景多元化网络空间安全人才培养及学科建设创新**”报告中提出了**网络空间安全的学科知识体系**如图**3-2**。



重点

图3-2 网络空间安全的学科知识体系

3.1 网络安全的体系结构

3. 网络空间安全防御体系

由于网络空间安全的威胁和隐患剧增，急需构建**新型网络空间安全防御体系**，并从传统线性防御体系向新型多层次立体化网络空间防御体系发展。以相关法律、准则、策略、机制和技术为基础，以网络安全管理及运作防御贯彻始终，以第一层物理层防御（子）体系、第二层网络层防御体系和第三层系统层与应用层防御体系构成新型网络空间防御（子）体系，可以实现多层防御的立体化安全区域，将网络空间中的节点分布到所有区域，其中所有活动支撑着其他区域的活动，且其他区域的活动同样可以对网络空间产生影响。构建的一种整体的网络空间安全立体防御体系如图3-3.

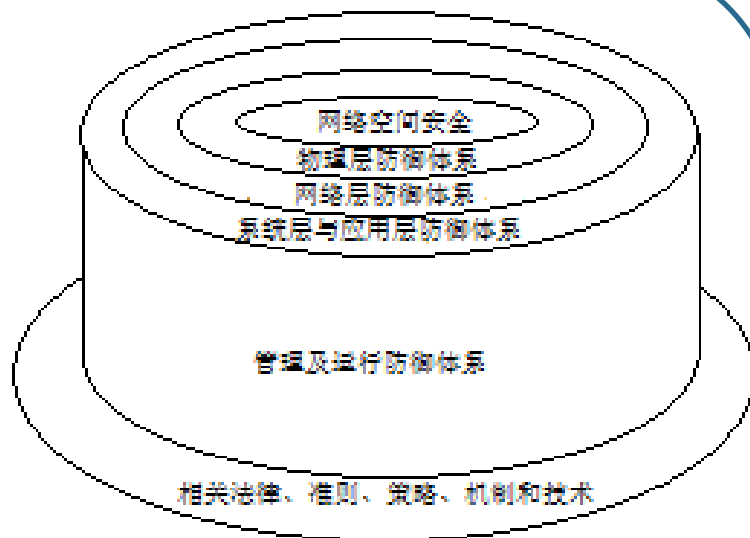


图3-3 网络空间安全防御体系

3.1 网络安全的体系结构

■ 3.1.2 OSI、TCP/IP及攻防体系结构

1. OSI网络安全体系结构

开放系统互连参考模型OSI（Open System Interconnect）由国际标准化组织（ISO）提出，主要用于解决异构网络及设备互联互通的开放式层次结构的研究。

OSI网络安全体系结构主要包括网络安全机制和服务。

1) 网络安全机制

ISO《网络安全体系结构》中，规定的**网络安全机制有8项**：加密机制、数字签名机制、访问控制机制、数据完整性机制、鉴别交换机制、信息量填充机制、路由控制机制和公证机制。

2) 网络安全服务

网络安全服务主要有5项：认证服务、访问控制服务、数据保密性服务、数据完整性服务和不可否认性服务。

3.1 网络安全的体系结构

■ 3.1.2 OSI、TCP/IP及攻防体系结构

- ① **认证服务**: 主要用于网络系统中认定识别实体(含用户及设备)和数据源等, 包括同等实体鉴别和数据源鉴别服务。
- ② **访问控制服务**; **访问控制**包括身份验证和权限验证。其服务主要防止非法/越权访问/使用网络资源。
- ③ **数据保密性服务**: 用于信息泄露、窃听等被动威胁等防御措施. **分为**: 信息保密、保护通信系统中的信息或网络数据。对于通信系统中信息, 又分为面向连接保密和无连接保密。
- ④ **数据完整性服务**: 主要包括**5种**: 带恢复功能的面向连接的数据完整性, 不带恢复功能的面向连接的数据完整性, 选择字段面向连接的数据完整性, 选择字段无连接的数据完整性和无连接的数据完整性, 主要用于满足不同用户、不同场合对数据完整性的要求。
- ⑤ **不可否认性服务**。是防止文件或数据发出者无法否认所发送的原有内容真实性的防范措施, 可用于证实已发生过的操作。

2. TCP/IP网络安全管理体系结构

TCP/IP网络安全管理体系结构,如图3-4.包括3方面:分层安全管理,安全服务与机制(认证,访问控制,数据完整性,抗抵赖性,可用及可控性,审计)、系统安全管理(终端系统安全,网络系统,应用系统).综合安全管理、技术和机制各方面,对网络安全整体管理与实施和效能充分发挥将起到至关重要作用。

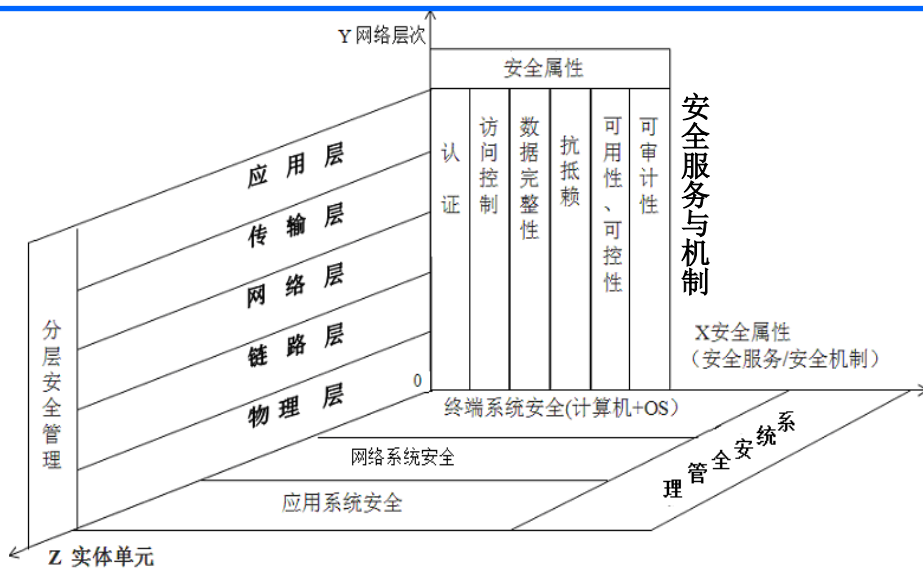


图3-4 TCP/IP网络安全管理体系结构

3.1 网络安全的体系结构

3. 网络安全的攻防体系结构

网络安全的攻防体系结构主要包括两大方面：攻击技术和防御技术。知其攻击才能有针对性搞好防御，主要的攻防体系结构，如图3-5所示。

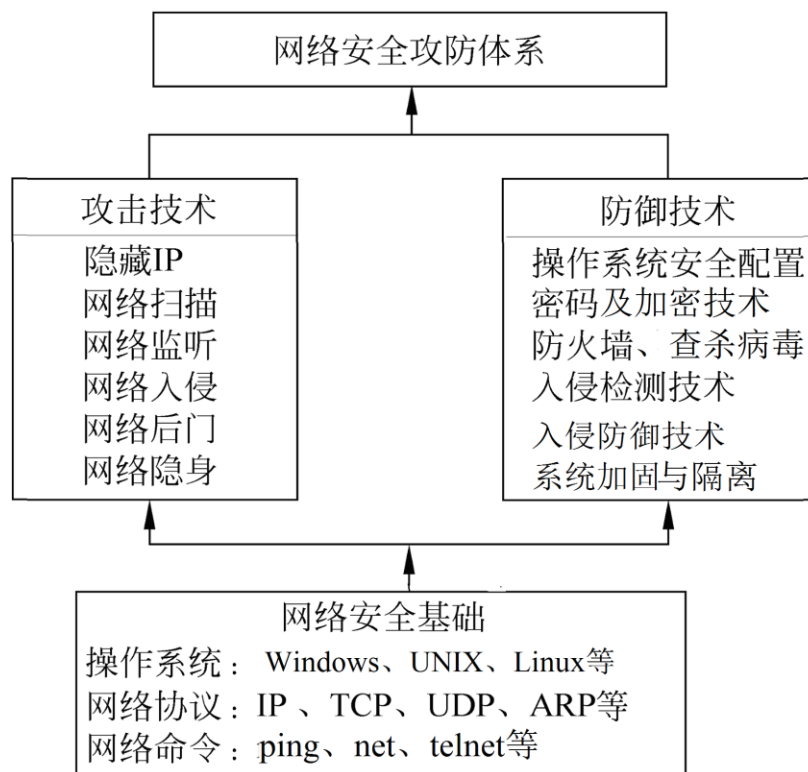


图3-5 网络安全攻防体系结构

3.1 网络安全的体系结构

■ 3.1.2 OSI、TCP/IP及攻防体系结构

为了做到“知己知彼，百战不殆”，需要掌握好网络安全的攻防体系结构、常见的攻击技术和手段，有助于更好地进行网络安全防御。

主要常见的网络攻击技术包括以下6种。

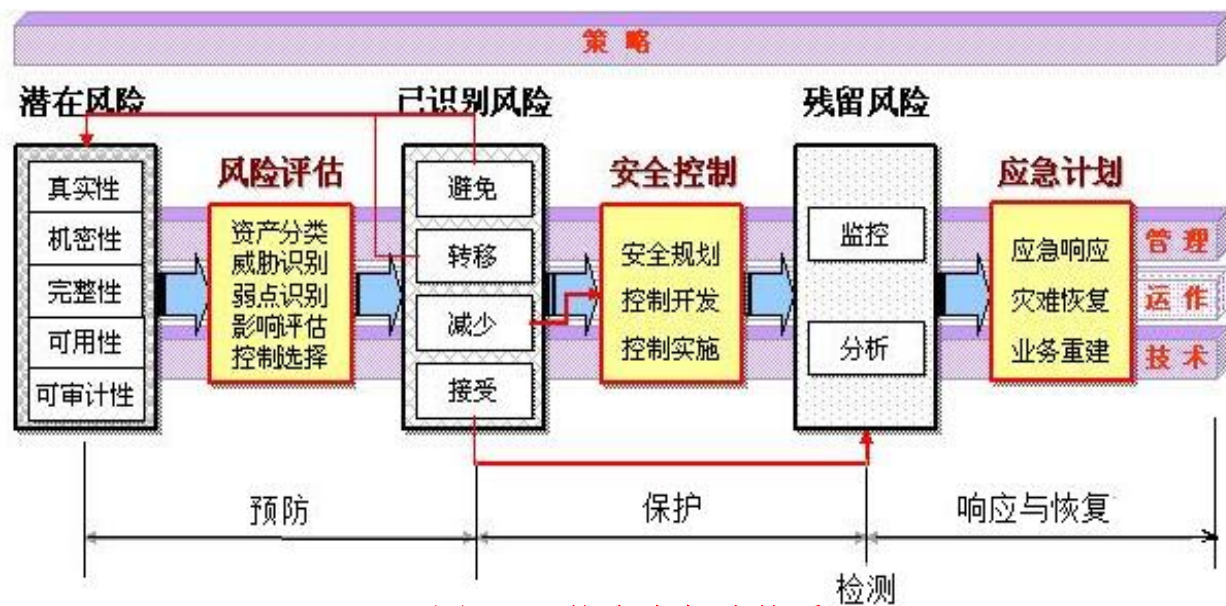
- 1) 隐藏IP。非授权者入侵目标终端网络前，先设法隐藏其IP地址。
- 2) 网络扫描。借助网络漏洞扫描工具探测目标终端或网站的操作系统、开放端口和漏洞等，为入侵攻击做好“踩点（探路）”准备。
- 3) 网络监听。黑客利用各种网络，借助监听程序探测窃取目标终端与其它设备之间的通信情况和机密信息。
- 4) 网络入侵。主要指入侵者利用不同的攻击技术和手段，通过网络入侵到目标主机或网站中，窃取机密资源、篡改数据或破坏等。
- 5) 网络后门。黑客成功入侵到目标设备或网站后，为了便于再次入侵和控制，在目标终端或网站种植后门程序。
- 6) 网络隐身。入侵结束后，为了防止被侦破、收集证据及惩治，不法者及时清除所有的入侵痕迹及日志。

主要防御技术包括系统安全配置与加固、实体（物理）安全与隔离技术、密码及加密技术、计算机病毒查杀、防火墙、入侵检测与防御技术、统一威胁资源管理（UTM）等。后面将陆续具体介绍。

3.1 网络安全体系结构

3.1.3 网络安全保障体系

网络安全保障体系如图3-6.其保障功能主要体现在对整个网络系统的风险及隐患进行及时的评估、识别、控制和应急处理等,便于有效地预防、保护、响应和恢复,确保系统安全运行。



•图3-6 网络安全保障体系

3.1 网络安全体系结构

3.1.3 网络安全保障体系

■ 1. 网络安全保障关键要素

网络安全保障关键要素包括四个方面：网络安全策略、网络安全管理、网络安全运作和网络安全技术，如图3-7。其中，**网络安全策略**为安全保障的核心，主要包括网络安全的战略、政策和标准。**网络安全管理**是指企事业单位的管理行为,主要包括安全意识、组织结构和审计监督。**网络安全运作**是企事业单位的日常管理行为,包括运作流程和对象管理。**网络安全技术**是网络系统的行为,包括安全服务、措施、基础设施和技术手段。



图3-7网络安全保障要素

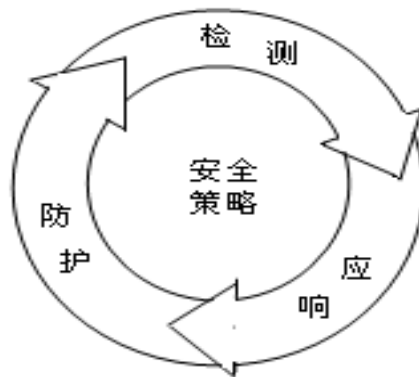


图3-8 P2DR模型示意图

3.1 网络安全体系结构

3.1.3 网络安全保障体系

■ 1. 网络安全保障关键要素

在企事业单位的管理机制下，只有利用运作机制借助技术手段，才可真正实现网络安全。通过网络安全运作，在日常工作中认真执行网络安全管理和网络安全技术手段，“**七分管理，三分技术，运作贯穿始终**”，**网络安全策略是核心，管理是关键，技术是保障**，其中的管理包括管理技术。

P2DR模型是美国ISS公司提出的**动态网络安全体系**的代表模型，也是**动态安全模型**，包含4个主要部分：**Policy(安全策略)**、**Protection(防护)**、**Detection(检测)**和**Response(响应)**。如上图3-8所示。



3.1 网络安全体系结构

3.1.3 网络安全保障体系

2. 网络安全保障总体框架

对于网络系统面临的各种威胁、隐患和风险，部分机构以往总是针对单一某项安全问题的传统措施，所提出的具体解决方案通常都有一定局限性，防范策略也难免顾此失彼。面对新的网络环境和威胁，需要建立一种以深度防御为特点的网络安全保障体系。

网络安全保障体系总体框架如图3-9。保障体系框架外围是风险管理、法律法规、标准的符合性。

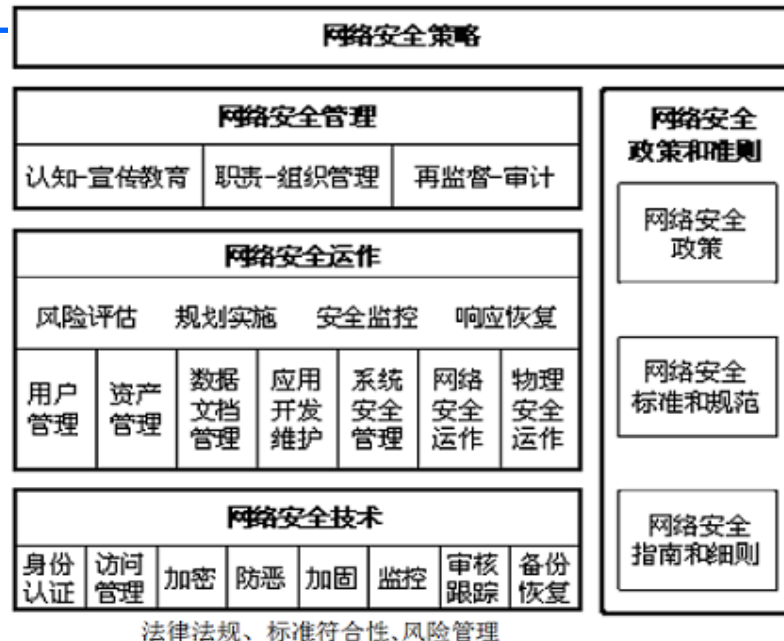


图3-9 网络安全保障体系框架

3.1 网络安全体系结构

3.1.3 网络安全保障体系

2. 网络安全保障总体框架

网络安全管理的本质是对网络信息安全风险进行动态及有效管理和控制。网络安全风险管理是网络运营管理的核心，其中的风险分为信用风险、市场风险和操作风险(包括网络信息安全风险)。网络安全保障体系架构包括五个部分：

1) 网络安全策略。属于整个体系架构顶层设计,起到总体宏观上的战略性和方向性指导作用.以风险管理为核心理念,从长远发展规划和战略角度整体策划。

2) 网络安全政策和标准。是对网络安全策略的逐层细化和落实，包括管理、运作和技术三个层面，各层面都有相应的安全政策和标准，通过落实标准政策规范管理、运作和技术，保证其统一性和规范性。

3) 网络安全运作。基于日常运作模式及其概念性流程(风险评估、安全控制规划和实施、安全监控及响应恢复).是网络安全保障体系重点,贯穿网络安全始终,也是安全管理和技术机制在日常运作中的实现,涉及运作流程和运作管理。

4) 网络安全管理。对网络安全运作至关重要，从人员、意识、职责等方面保证网络安全运作的顺利进行。

5) 网络安全技术。网络安全运作需要的网络安全基础服务和基础设施的有力支持。先进完善的网络安全技术可极大提高网络安全运作的有效性，从而达到网络安全保障体系的目标，实现整个生命周期（预防、保护、检测、响应与恢复）的风险防范和控制。

网络安全保障包括：信息安全策略和（ ）。

- ☐ A 信息安全管理
- ☐ B 信息安全技术
- ☐ C 信息安全运作
- ☒ D 上述三点

提交

网络安全保障体系架构的外围是（ ）。

- ☐ A 风险管理
- ☐ B 法律法规
- ☐ C 标准符合性
- ☒ D 上述三点

提交

3.1 网络安全体系结构

3.1.4 可信计算网络安全防护体系

国务院《国家中长期科技发展规划纲要(2006—2020年)》提出“以发展高可信网络为重点,开发网络安全技术及相关产品,建立网络安全技术保障体系”,将可信计算列为发展重点,可信计算标准系列逐步制定,核心技术设备形成体系.多名中国院士提议成立可信计算产业联盟2014年成立。

沈昌祥院士强调:可信计算是网络空间战略最核心技术之一,要坚持“五可一有”的可信计算网络安全防护体系包括:一可知是对全部开源系统及代码完全掌握其细节;二可编是完全理解开源代码并可自主编写;三可重构,面向具体应用场景和安全需求,对基于开源技术的代码进行重构,形成定制化的新体系结构;四可信,通过可信计算技术增强自主操作系统免疫性,防范自主系统中的漏洞影响系统安全性;五可用,做好应用程序与操作系统的适配工作,确保自主操作系统能替代国外产品。“一有”是对最终的自主操作系统拥有自主知识产权,并处理好所用开源技术的知识产权问题。

☺讨论思考:

- 1) 请简述ISO的网络安全体系结构?
- 2) 网络安全的攻防体系具体包括哪些?
- 3) 网络安全保障体系架构包括哪些?
- 4) 网络空间安全体系包括哪几个方面?

可信计算网络安全防护体系

五可

一有

3.2 网络安全相关法律法规

3.2.1 国外网络安全相关的法律法规

现代信息化社会各种信息技术发展与更新很快,在全球广泛应用时间却较短,法律体系在较短时期内不可能十分完善,正随着信息化社会不断发展完善。

(1) 国际合作立法打击网络犯罪

20世纪90年代后,世界多国为了更好打击网络犯罪活动都利用法律手段,欧盟已成为在刑事领域做出国际间规范的典型.2000年两次颁布《网络刑事公约》,现有43个国家借鉴.在不同国家的刑事立法中,印度做法具有一定代表性,在2000年6月颁布了《信息技术法》,制定出一部规范网络安全的基本法.一些国家修订原有刑法,美国2000年修订原《计算机反欺诈与滥用法》,增加法人责任,补充了类似规定。

(2) 数字化技术保护措施的法律

1996年12月,世界知识产权组织做出“禁止擅自破解他人数字化技术保护措施”规定,作为保障网络安全的一项主要内容进行规范.后来欧盟、日本、美国等大多数国家都将其作为一种网络安全保护规定,纳入本国的法律条款。

3.2 网络安全相关法律法规

3.2.1 国外网络安全相关的法律法规

(3) 同“入世”有关的网络法律

1996年12月,联合国贸易法委员会的《电子商务示范法》在联合国第51次大会通过,对网络市场中数据电文、网上合同成立及生效的条件、传输等专项领域的电子商务等,都做了十分明确的规范,1998年7月新加坡的《电子交易法》出台。1999年世贸组织西雅图外交会议上,制定“电子商务”规范成为一个主要议题。

(4) 其它相关立法

很多国家在制定保障网络健康发展的法规的同时,还专门制定了综合性的、原则性的网络基本法。如韩国2000年修订的《信息通信网络利用促进法》,其中,对“信息网络标准化”和**实名制**的规定,对成立“韩国信息通信振兴协会”等民间自律组织的规定等。在印度在政府机构成立了“网络事件裁判所”,以解决影响网络安全的很多民事纠纷。

(5) 民间管理、行业自律及道德规范

各国对规范网络使用行为,都非常注重发挥民间组织作用,特别是行业自律功能。德国、英国、澳大利亚等学校中网络使用“行业规范”十分严格。澳大利亚每周都要求教师填写一份保证书,申明不从网上下载违法内容。德国的网络用户一旦有校方规定禁止的行为,服务器立即会发出警告。慕尼黑大学、明斯特大学等院校都订有《关于数据处理与信息技术设备使用管理办法》且要求严格遵守。

3.2 网络安全相关法律法规

3.2.2 国内网络安全相关的法律法规

案例3-2

中国政府高度重视网络安全。自2018 年以来全国公安机关连续5 年开展“净网”专项行动，共侦破各类网络犯罪案件25.5 万起，抓获犯罪嫌疑人38.5 万名。同时，深化“一案双查”，对网络犯罪案件中涉及的企业，依法严查不履行网络安全管理义务的行为。自开展专项行动以来，共对16.2 万家违法互联网企业、单位依法予以行政处罚，有力维护了网络空间安全和网上秩序稳定。



3.2 网络安全相关法律法规

3.2.2 国内网络安全相关的法律法规

中国从网络安全整治管理的需要出发，国家及相关部门、行业 and 地方政府相继制定了多项有关网络安全的法律法规。

中国网络安全法律体系分为以下三个层面：

第一层面：法律。是全国人民代表大会及其常委会通过的法律规范。我国同网络安全相关的法律有：《立法法》、《宪法》、《刑法》、《治安管理处罚条例》、《刑事诉讼法》、《国家安全法》、《保守国家秘密法》、《行政处罚法》、《行政诉讼法》、《关于维护互联网安全的决定》、《网络安全法》、《行政复议法》、《国家赔偿法》、《个人信息保护法》等。

第二个层面：行政法规和战略部署。主要是国务院为执行宪法和法律而制定的法律规范。与网络信息安全有关的行政法规包括《计算机信息系统安全保护条例》、《计算机信息网络国际联网管理暂行规定》、《计算机信息网络国际联网安全保护管理办法》、《商用密码管理条例》、《中华人民共和国电信条例》、《互联网信息服务管理办法》、《计算机软件保护条例》、《网络安全审查办法》等。



3.2 网络安全相关法律法规

3.2.2 国内网络安全相关的法律法规

第三个层面：地方性法规、规章、规范性文件。主要是国务院各部、委根据法律和国务院行政法规与法律规范，以及省、自治区、直辖市和较大的市人民政府根据法律、行政法规及其法律规范性文件。

公安部制定的《计算机信息系统安全专用产品检测和销售许可证管理办法》、《计算机病毒防治管理办法》、《金融机构计算机信息系统安全保护工作暂行规定》和有关计算机安全员培训要求等。

工业和信息化部制定的《互联网电户公告服务管理规定》、《软件产品管理办法》、《计算机信息系统集成资质管理办法》、《国际通信出入口局管理办法》、《国际通信设施建设管理规定》、《中国互联网络域名管理办法》、《电信网间互联管理暂行规定》等。

☺讨论思考：

- 1) 为什么说法律法规是网络安全体系的重要保障和基石？
- 2) 国外的网络安全法律法规对我们有何启示？
- 3) 我国网络安全立法体系框架分为哪三个层面？

我国网络安全立法体系框架分为（ ）。

- ☐ A 构建法律、地方性法规和行政规范
- ☒ B 法律、行政法规和地方性法规、规章、规范性文件文档
- ☐ C 法律、行政法规和地方性法规
- ☐ D 此处添加选项内容

提交

3.3 网络安全评估准则和方法

3.3.1 国外网络安全评估标准

网络安全评估准则是保障网络安全技术和产品,在设计、研发、建设、实施、使用、测评和管理维护过程中,解决一致性、可靠性、可控性、先进性和符合性的**技术规范**和**依据**.深受各国政府重视,是各国国家安全工作中不可缺少的一项内容。

1. 美国TCSEC(橙皮书)

1983年由美国国防部制定的**可信计算机系统评价准则**（**Trusted Computer Standards Evaluation Criteria, TCSEC**），即网络安全**橙皮书**或**桔皮书**，主要利用计算机安全级别**评价计算机系统的安全性**。将安全分为4个方面（类别）：安全政策、可说明性、安全保障和文档。橙皮书将安全的级别从低到高分成4个类别：D类、C类、B类和A类，并分为7个安全级别，从低到高依次为D、C1、C2、B1、B2、B3和A级。如表3-1所示。

3.3 网络安全评估准则和方法

3.3.1 国外网络安全评估标准

可信计算系统评价准则（TCSEC）[网络安全橙皮书](#)[评价系统安全性](#)

表3-1 网络系统安全级别分类

类别	级别	名称	主要特征	适用对象	现实案例
D	D	低级保护	没有安全保护	个人/非敏感	DOS、旧Windows
C	C1	自主安全保护	自主存储控制	小型商业	基础Linux/Unix
	C2	受控存储控制	单独的可查性，安全标识	商业企业	Windows Server、企业Linux
B	B1	标识的安全保护	强制存取控制，安全标识	政府机构	专用安全操作系统
	B2	结构化保护	面向安全的体系结构，较好的抗渗透能力	军事/情报	历史专用系统
	B3	安全区域	存取监控、高抗渗透能力	高度机密	核武器/密码系统
A	A	验证设计	形式化的最高级描述和验证	极端关键	航天/核控制（理论）

通常，网络系统的安全级别设计需要从数学角度上进行验证，而且必须进行秘密通道分析和可信任分布分析（见表3-1）。

3.3 网络安全评估准则和方法

2. 美国联邦准则(FC)

美国联邦准则(FC)标准参照了加拿大的评价标准CTCPEC与橙皮书TCSEC，目的是提供TCSEC的升级版本，同时保护已有建设和投资。FC是一个过渡标准，之后结合ITSEC发展为联合公共准则。

3. 欧洲ITSEC(白皮书)

信息技术安全评估标准ITSEC(Information Technology Security Evaluation Criteria), 俗称欧洲的白皮书, 将保密作为安全增强功能, 仅限于阐述技术安全要求, 并未将保密措施直接与计算机功能相结合。ITSEC是欧洲的英国、法国、德国和荷兰四国在借鉴橙皮书的基础上, 于1989年联合提出的。橙皮书将保密作为安全重点, 而ITSEC则将首次提出的完整性、可用性与保密性作为同等重要的因素, 并将可信计算机概念提高到可信信息技术高度。ITSEC定义了从E0级(不满足品质)到E6级(形式化验证)7个安全等级。对每个系统安全功能可分别定义。ITSEC预定义了10种功能, 其中前5种与桔皮书中的C1~B3级基本类似。

3.3 网络安全评估准则和方法

4.通用评估准则(CC)

通用评估准则(Common Criteria for IT Security Evaluation,CC)由美国等国家与ISO联合提出,并结合FC及ITSEC的主要特征,强调将网络信息安全的功能与保障分离,将**功能需求**分为9类63族(项),将**保障**分为7类29族。CC的**先进性体现在**其结构的开放性、表达方式的通用性、结构及表达方式的内在完备性和实用性四个方面。CC标准于1996年发布第一版,充分结合并替代了ITSEC、TCSEC、CTCPEC等国际上重要的信息安全评估标准而**成为通用评估准则**。

主要确定评估信息技术产品和系统安全性的基本准则,提出**国际上公认的表述信息技术安全性的结构**,将安全要求分为规范产品和系统安全行为的功能要求,以及解决正确有效的实施这些功能的保证要求。**中国测评中心**主要采用CC进行测评,其内容可查阅相关网站。

3.3 网络安全评估准则和方法

4.通用评估准则(CC)

保障等级 (Evaluation Assurance Levels, EALs) :

EAL1 (Functionally Tested / 功能性测试) : 主要通过功能性测试验证基本安全性能的实现。

EAL2 (Structurally Tested / 结构化测试) : 包括结构化的测试和高层设计文档的审查。

EAL3 (Methodically Tested and Checked / 方法化测试和检查) : 强调方法论测试和开发环境的进一步审查。

EAL4 (Methodically Designed, Tested, and Reviewed / 方法化设计、测试与评审) : 对系统的设计进行方法化审核, 是商业软件产品的常见最大目标。

EAL5 (Semiformally Designed and Tested / 半形式化设计和测试) : 要求半形式化的设计描述和更深入的测试, 包括高保障应用。

EAL6 (Semiformally Verified Design and Tested / 半形式化验证设计和测试) : 适合需要高保障的应用程序, 强调半形式化验证。

EAL7 (Formally Verified Design and Tested / 形式化验证设计和测试) : 最高级别, 要求全面的形式化设计验证和测试。

3.3 网络安全评估准则和方法

5.ISO 安全体系结构标准

国际标准ISO7498-2-1989《信息处理系统·开放系统互连、基本模型·第2部分：安全体系结构》，给出**网络安全服务与有关机制的基本描述**，确定在参考模型内部**可提供的服务与机制**。从体系结构描述ISO基本参考模型之间的网络安全通信所提供的**网络安全服务和机制**及其在安全体系结构中的**关系**，建立了开放互连系统的安全体系结构框架，并在身份认证、访问控制、数据加密、数据完整性和防止抵赖方面，提供了5种可选择网络安全服务。如表3-2。

表3-2 ISO提供的安全服务

服 务	用 途
身份验证	是证明用户及服务器身份的过程
访问控制	用户身份一经过验证就发生访问控制，这个过程决定用户可以使用、浏览或改变哪些系统资源
数据保密	这项服务通常使用加密技术保护数据免于未授权的泄露，可避免被动威胁
数据完整性	这项服务通过检验或维护信息的一致性，避免主动威胁
防止抵赖	抵赖是指否认参加全部或部分事务的能力，防抵赖服务提供关于服务、过程或部分信息的起源证明或发送证明。



3.3 网络安全评估准则和方法

5.ISO 安全体系结构标准

安全服务：5类—认证、访问控制、数据保密性、数据完整性、不可否认（抗抵赖）性。

安全机制：8类—加密、数字签名、访问控制、数据完整性、鉴别交换、业务填充、路由控制、公证。

安全管理：3类—系统安全管理、安全服务管理、安全机制管理。

3.3 网络安全评估准则和方法

现在，国际上通行的与网络信息安全有关标准可分为3类，如图3-10所示。

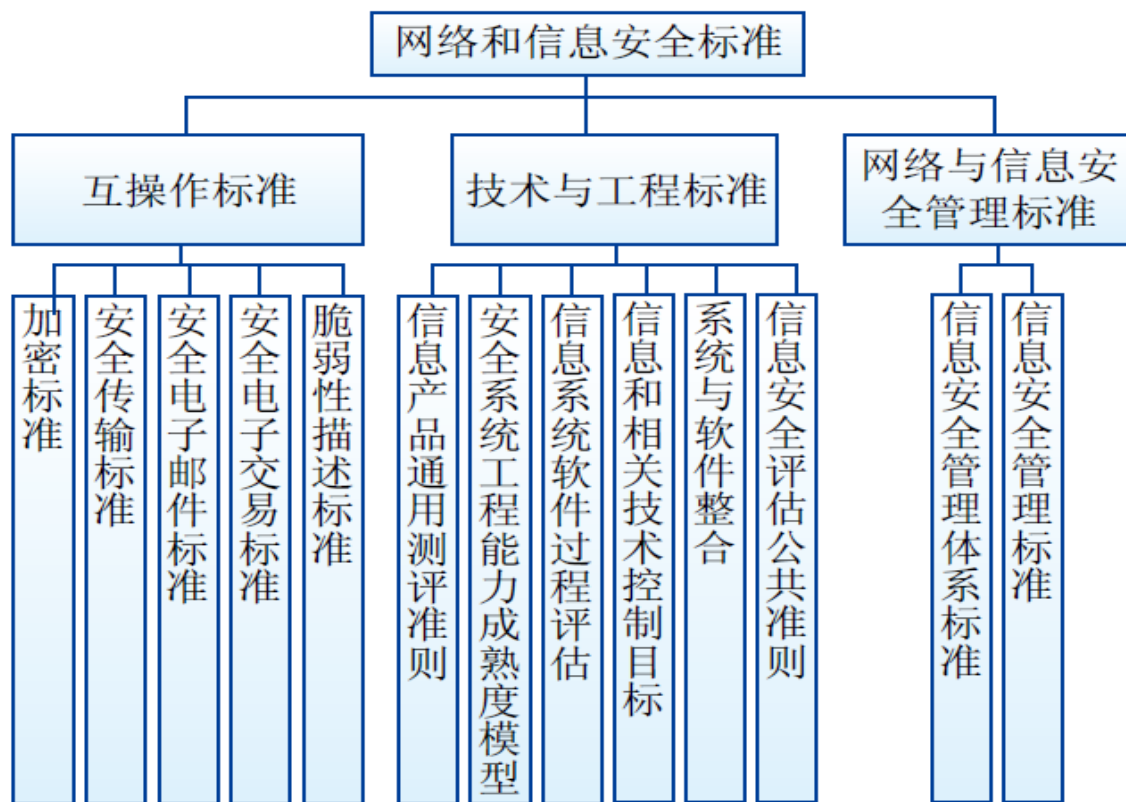


图3-10 有关网络和信息安全的标准种类

3.3 网络安全评估准则和方法

3.3.2 国内网络安全评估准则

1.系统安全保护等级划分准则(等保2.0)

1999年10月经过国家质量技术监督局批准发布了“系统安全保护等级划分准则”,此准则主要依据GB-17859《计算机信息系统安全保护等级划分准则》和GA-163《计算机信息系统安全专用产品分类原则》等文件,将计算机信息系统安全保护划分为5个级别,如表3-3。

2006公安部
修订并实施

表3-3我国计算机信息系统安全保护等级划分

等级	名称	描述
自主保护级	第一级	用户自我保护级 安全保护机制可以使用户具备安全保护的能力,保护用户信息免受非法的读写破坏。(个人电脑)
指导保护级	第二级	系统审计保护级 除具备第一级所有安全保护功能外,要求创建和维护访问的审计跟踪记录,使所有用户对自身行为合法性负责(OA系统)
监督保护级	第三级	安全标记保护级 除具备前一级所有的安全保护功能外,还要求以访问对象标记的安全级别限制访问者的权限,实现对访问对象的强制访问(政府或军工)
强制保护级	第四级	结构化保护级 除具备前一级所有的安全保护功能外,还将安全保护机制划分为关键部分和非关键部分,对关键部分可直接控制访问者对访问对象的存取,从而加强系统的抗渗透能力(银行的核心交易系统)
专控保护级	第五级	访问验证保护级 除具备前一级所有的安全保护功能外,还特别增设了访问验证功能,负责仲裁访问者对访问对象的所有访问(国家级关键基础设施)

3.3 网络安全评估准则和方法

2. 我国网络信息安全标准化现状

因网络安全逐渐纳入国家安全战略新高度，网络信息安全标准化事关国家信息化安全建设与实施，是网络信息安全保障体系的重要组成部分。各国通常借鉴国际标准，并结合本国实际情况制定并完善本国的信息安全标准化组织和标准。

中国的信息安全标准化建设，主要按照国务院授权，在国家质量监督检验检疫总局管理下，由国家标准化管理委员会统一管理全国标准化工作，该委员会下设有255个专业技术委员会。中国标准化工作实行统一管理与分工负责相结合的管理体制，有88个国务院有关行政主管部门和国务院授权的有关行业协会分工管理本部门、本行业的标准化工作，有31个省、自治区、直辖市政府有关行政主管部门分工管理本行政区域内、本行业的标准化工作。1984年成立的全国信息技术安全标准化技术委员会（CITS），在国家标准化管理委员会及工业和信息化部共同领导下负责全国IT领域和与ISO/IEC JTC1对应的标准化工作，下设24个分技术委员会和特别工作组，为国内最大的标准化技术委员会工作范围是负责信息和通信安全的通用框架、方法、技术和机制的标准化，主要从事国内外对应的标准化工作。

2016年8月中央网络安全和信息化领导小组、国家质量监督检验检疫总局和国家标准化管理委员会制定了《关于加强国家网络安全标准化工作的若干意见》，对于网络安全标准化起到了极为重要作用。我国信息安全标准化工作起步晚、发展快，积极借鉴国际标准原则，制定了一系列信息安全标准和行业标准。

3.3 网络安全评估准则和方法

3.3.3 网络安全常用测评方法

网络安全测评也要讲求方式方法，只有使用恰当的方法进行**全面、彻底、有效**的安全测评，才能**准确查找并分析**网络安全漏洞、隐患和风险，根据评估结果与业务的安全需求及目标，及时**采取有效措施提高安全防御能力**。实际安全测评应按照网络安全相关的**目的、要求、策略、技术、方法和标准**等进行。

1. 测评目的和方法

1) 网络安全测评目的

网络安全测评目的包括：

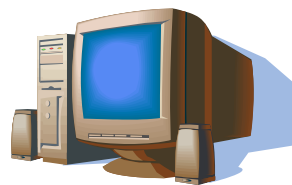
- ① 彻底搞清企事业单位具体信息资产的实际价值及状况；
- ② 明确企事业单位信息资源，及其在机密性、完整性、可用性、可控性和可审查性方面的具体威胁风险及实际程度；
- ③ 通过深入调研分析搞清网络系统实际存在的**具体漏洞隐患及风险**的状况；
- ④ 确定同本机构信息资产有关的风险和具体需要改进之处；
- ⑤ 提出改变现状的具体建议和方案，将风险降低到可接受的程度；
- ⑥ 做好构建合适的安全计划和策略的准备。

3.3 网络安全评估准则和方法

2) 网络安全常用测评类型

网络安全通用的测评类型分为5个：

- ① **系统级漏洞测评**。主要测评企事业单位整个系统的漏洞、系统安全隐患与风险、基本安全策略及具体实施状况等。
- ② **网络级风险测评**。主要测评企事业单位相关的所有网络系统及信息基础设施实际存在的隐患和风险范围方面的具体情况。
- ③ **机构的风险测评**。对机构进行整体风险测评分析，对其信息资产存在的具体威胁及隐患、问题和处理方式方法，包括对实体系统及运行环境的各种安全等进行测评。
- ④ **实际入侵测试**。对机构重要的网络系统及业务应用（服务）安全进行网络入侵的实际反应能力等方面的安全性测试检验，便于采取有效措施。
- ⑤ **审计**。深入实际检查具体的网络安全策略、记录和该组织具体执行情况。



3.3 网络安全评估准则和方法

3) 网络安全常用调研及测评方法

在实际调研和测评时，主要收集3种基本信息源：调研对象、文本查阅和物理检验。调研对象主要是指现有系统安全和组织实施相关人员，重点为熟悉情况和管理者。为了准确测评所保护的信息资源及资产，调研提纲应尽量简单易懂，且所提供的信息与调研人员无直接利害关系，同时审查现有的安全策略及关键的配置情况，包括已经完成和正在草拟或修改的文本。还应搜集对该机构的各种设施的审查信息



3.3 网络安全评估准则和方法

2.网络安全测评标准和内容

- ① **安全测评前提**。在进行网络安全实际测评前，主要**重点考察3**个方面的**测评因素**：服务器和终端及其网络设备安装**区域环境**的安全性；设备和设施的**质量安全**可靠性；外部**运行环境**及内部运行环境的相对安全性，**系统管理员**可信任度和配合测评愿意情况等。
- ② **测评依据和标准**。以上述**ISO** 或国家有关的通用评估准则**CC**、《信息安全技术评估通用准则》《计算机信息系统安全保护等级划分准则》《信息安全等级保护管理办法（试行）》和**GB/T 36958—2018**《信息安全技术 网络安全等级保护 安全管理中心技术要求》等作为评估标准。此外，经过各方认真研究和协商讨论达成的相关标准及协议，也可作为网络安全测评的重要依据。
- ③ **具体测评内容**。网络安全的评估内容主要包括：安全策略测评、网络实体（物理）安全测评、网络体系安全测评、安全服务测评、病毒防护安全性测评、审计安全性测评、备份安全性测评、紧急事件响应测评和安全组织与管理测评等。



3.3 网络安全评估准则和方法

3. 网络安全策略测评

1) **测评事项**。利用网络系统规划及设计文档、安全需求分析文档、网络安全风险测评文档和网络安全目标，测评网络安全策略的有效性。

2) **测评方法**。采用专家分析的方法，主要测评安全策略实施及效果，包括：安全需求是否满足、安全目标是否能够实现、安全策略是否有效、实现是否容易、是否符合安全设计原则、各安全策略的一致性。

3) **测评结论**。按照测评的具体结果，对比网络安全策略的完整性、准确性和一致性。

4. 网络实体安全测评

1) **实体安全的测评项目**。主要测评项目包括：网络基础设施、配电系统、服务器、交换机、路由器、配线柜、主机房、工作站、工作间、记录媒体及运行环境等。

2) **测评方法**。主要采用专家分析法，包括测评对物理访问控制（包括安全隔离、门禁控制、访问权限和时限、访问登记等）、安全防护措施（防盗、防水、防火、防振等）、备份及运行环境等的要求是否实现、是否满足安全需求。

3) **测评结论**。根据实际测评结果，确定网络系统实际实体安全及运行环境情况。



3.3 网络安全评估准则和方法

5. 网络体系的安全性测评

1) 网络隔离的安全性测评

① **测评项目**。主要包括以下3个方面：

- ◆ 网络系统内部与外部的隔离的安全性
- ◆ 内部虚网划分和网段的划分的安全性
- ◆ 远程连接（VPN、交换机、路由器等）的安全性

② **测评方法**。主要利用检测侦听工具，测评防火墙过滤和交换机、路由器实现虚拟网划分的情况。采用漏洞扫描软件测评防火墙、交换机和路由器是否存在安全漏洞及程度。

③ **测评结论**。依据实际测评结果，表述网络隔离的安全性情况。

2) 网络系统配置安全性测评

① **测评项目**。主要包括以下7个方面：

- ◆ 网络设备（如路由器、交换机、Hub）的网络管理代理默认值是否修改；
- ◆ 防止非授权用户远程登录路由器、交换机等网络设备；
- ◆ 业务服务模式的安全设置是否合适；
- ◆ 业务服务端口开放及具体管理情况；
- ◆ 应用程序及服务软件版本加固和更新程度；
- ◆ 网络操作系统的漏洞、隐患及更新情况；
- ◆ 网络系统设备设施的安全性情况



3.3 网络安全评估准则和方法

② **测评方法和工具**。常用的主要测评方法和工具包括：

- ◆ 采用漏洞扫描软件，测试网络系统存在的漏洞和隐患情况；
- ◆ 检查网络系统采用的各设备采用安全性得到认证产品情况。
- ◆ 依据设计文档，检查系统配置是否被更改和原因等是否满足安全需求。

③ **测评结论**。依据测评结果，表述网络系统配置的安全情况。

3) 网络防护能力测评

① **测评内容**。主要对拒绝服务、电子欺骗、网络侦听、入侵等攻击形式是否采取了相应的防护措施及防护措施是否有效。

② **测评方法**。用模拟攻击、漏洞扫描软件，测评网络防护能力。

③ **测评结论**。依据具体测评结果，具体表述网络防护能力。

4) 服务的安全性测评

① **测评项目**。主要包括两个方面：

- ◆ 服务隔离的安全性。以信息机密级别要求进行服务隔离。
- ◆ 服务的脆弱性分析。主要测试系统开放的服务DNS、FTP、E-Mail、HTTP等，是否存在安全漏洞和隐患。

② **测评方法**。常用的测评方法主要有两种：

- ◆ 采用系统漏洞检测扫描工具，测试系统开放服务是否存在安全漏洞和隐患；
- ◆ 模拟各项业务和服务运行环境及条件，检测具体运行情况。

③ **测评结论**。依据实际测评结果，表述网络系统服务的安全性。

3.3 网络安全评估准则和方法

5) 应用系统的安全性测评

- ① 测评项目。主要测评应用程序是否存在安全漏洞；应用系统的访问授权、访问控制等防护措施（加固）的安全性。
- ② 测评方法。主要采用专家分析和模拟测试的方法。
- ③ 测评结论。依实际测评结果，对应用程序安全性全面评价。

6. 安全服务的测评

- 1) 测评项目。主要包括：认证、授权、数据安全性（保密性、完整性、可用性、可控性、可审查性）、逻辑访问控制等。
- 2) 测评方法。采用扫描检测等工具截获数据包，分析上述各项具体满足安全需求情况。
- 3) 测评结论。依据测评结果，表述安全服务的充分性和有效性。

7. 病毒防护安全性测评

- 1) 测评项目。主要检测服务器、工作站和网络系统配备有效的防病毒软件及病毒清查的执行情况。
- 2) 测评方法。主要利用专家分析和模拟测评等测评方法。
- 3) 测评结论。依据测评结果，表述计算机病毒防范实际情况。

3.3 网络安全评估准则和方法

8. 审计的安全性测评

- 1) 测评项目。主要包括：审计数据的生成方式安全性、数据充分性、存储安全性、访问安全性及防篡改的安全性。
- 2) 测评方法。主要采用专家分析和模拟测试等测评方法。
- 3) 测评结论。依据测评具体结果表述审计的安全性。

9. 备份的安全性测评

- 1) 测评项目。主要包括：备份方式的有效性、备份的充分性、备份存储的安全性和备份的访问控制情况等。
- 2) 测评方法。采用专家分析的方法，依据系统的安全需求、业务的连续性计划，测评备份的安全性情况。
- 3) 测评结论。依据测评结果，表述备份系统的安全性。

10. 紧急事件响应测评

- 1) 测评项目。主要包括：紧急事件响应程序及其有效应急处理情况，以及平时的应急准备情况(备份、培训和演练情况)。
- 2) 测评方法。模拟紧急事件响应条件，检测响应程序是否有序且有效处理安全事件。
- 3) 测评结论。依据实际测评结果，对紧急事件响应程序和应急预案及措施的充分性、有效性对比评价。

3.3 网络安全评估准则和方法

11. 安全组织和管理测评

1) 相关测评项目

- ① 建立安全组织机构和设置安全机构（部门）情况；
- ② 检查网络管理条例及落实情况，明确规定网络应用目的、应用范围、应用要求、违反惩罚规定、用户入网审批程序等情况；
- ③ 所有相关人员的网络安全职责是否明确并具体落实；
- ④ 具体查清合适的信息处理设施授权程序；
- ⑤ 实施网络配置管理情况；
- ⑥ 规定各作业的合理工作规程情况；
- ⑦ 明确具体详实的人员安全管理规程情况；
- ⑧ 记载具体、有效的安全事件响应程序及预案情况；
- ⑨ 有关人员涉及各种管理规定，对其详细内容掌握情况；
- ⑩ 机构相应的保密制度及落实情况；
- ⑪ 账号、口令、权限等授权和管理制度及落实情况；
- ⑫ 定期安全审核和安全风险测评制度及落实情况；
- ⑬ 管理员定期培训和资质考核制度及落实情况。

2) 安全测评方法

主要利用专家分析的方法、考核法、审计方法和调查的方法。

3) 主要测评结论

由实际测评结果，评价安全组织机构和安全管理有效性。

讨论思考：

- (1) 橙皮书将安全级别从低到高分成哪些类和级别？
- (2) 国家将计算机安全保护划分为哪5个级别？
- (3) 网络安全测评方法具体主要有哪些？





*3.4 网络安全管理原则及制度

3.4.1 网络安全管理基本原则

强化网络安全，应当遵守网络安全管理基本原则：

(1) 多人负责的原则：为了确保网络安全、职责明确，对各种与网络安全有关的事项，如同管理重要钱物一样应由多人分管负责并在现场当面认定签发。系统主管领导应忠诚可靠、能力强；网络系统安全负责人应具有丰富的工作经验，同时明确安全指标、岗位职责和任务；安全管理员应及时签署安全工作情况记录，以及安全工作保障落实和完成情况。

需要签发的与安全有关的主要事项包括：

- 1) 全部处理的任何与保密有关的信息。
- 2) 信息处理系统使用的媒介发放与收回。
- 3) 访问控制使用的证件发放与收回。
- 4) 系统软件的设计、实现、修改和维护。
- 5) 业务应用软件和硬件的修改和维护。
- 6) 重要程序和数据的增加删改与销毁等。

(2) 有限任期原则：网络安全人员不宜长期担任与安全相关的职务，以免产生永久“保险”职位的观念，可通过强制休假、培训或轮换岗位等方式适当调整。



*3.4 网络安全管理原则及制度

(3) 坚持职责分离的原则：网络系统重要相关人员应各司其职、各负其责、业务权限及分工各异，除了主管领导批准的特殊情况之外，不应询问或参与职责以外与网络安全有关的事务。

任何以下两项工作都应分开，由不同人员完成：

- 1) 网络系统和应用系统的研发与实现。
- 2) 具体业务处理系统的检查及验收。
- 3) 重要数据和文件等具体业务操作。
- 4) 计算机网络管理和系统维护工作。
- 5) 机密资料的接收和传送。
- 6) 具体的安全管理和系统管理。
- 7) 系统访问证件的管理与其他工作。
- 8) 业务操作与数据处理系统使用存储介质的保管等。

网络系统安全管理部门应根据管理原则和系统处理数据的保密性要求，制定相应的管理制度，并采取相应的网络安全管理规范。包括以下内容：

- 1) 根据业务的重要程度，测评系统的具体安全等级。
- 2) 由其安全等级，确定安全管理的具体范围和侧重点。
- 3) 规范和完善“网络/信息中心”机房出入管理制度。



*3.4 网络安全管理原则及制度

(4) 严格管理操作规程

应当严格执行管理操作规程的规定和要求，坚持职责分离和多人负责等原则，所有业务人员都应做到各司其职、各负其责，不能超越各自管辖的权限范围。特别是国家安全保密机构、银行、证券等单位和财务机要部门等。

(5) 网络系统安全监测和审计制度

建立健全网络系统安全监测和审计制度，确保系统安全，并能够及时发现、及时处理。

(6) 建立健全网络系统维护制度

在网络系统维护之前须经主管部门批准，并采取数据保护措施，如数据备份等。在系统维护时，必须有网络安全管理人员在场，对于故障的原因、维护内容和维护前后的情况应详细认真记录并进行签字确认。

(7) 完善应急措施

制定并执行网络系统出现意外紧急情况时的应急预案，有尽快恢复的应急对策，并将损失减到最小限度。同时建立健全相关人员聘用和离职调离安全保密制度，对工作调动和离职人员要及时调整并进行相应的权限控制。

*3.4 网络安全管理原则及制度

3.4.2 网络安全管理机构 and 制度

网络安全管理机构及规章制度是各级组织和制度的根本保障。网络安全管理制度包括 人事资源管理、资产物业管理、教育培训、资格认证、人事考核鉴定制度、动态运行机制、日常工作规范、岗位责任制度等。

1. 完善管理机构和岗位责任制

网络安全涉及整个企事业单位及系统的安全、声誉、效益和影响。网络安全系统安全保密 工作最好由单位主要领导负责，必要时设置专门机构，如网络安全管理中心等，协助主要领导管理。对于重要单位或要害部门的安全保密工作，分别由安全、保密、保卫及技术部门分工负责。所有领导机构、重要网络系统的安全组织机构，包括网络安全审查机构、安全决策机构、安全管理机构，都要建立和健全各项规章制度。完善专门的网络安全防范组织和人员。各机构应设立相应的网络安全管理委员会或安全小组、安全员。网络安全组织成员应由主管领导、公安保卫、信息中心、人事、审计等部门的工作人员组成，必要时可聘请相关部门的专家。网络安全组织也可成立专门的独立及认证机构。对安全组织的成立、成员的变动等应定期向公安网络安全监察部门报告。对计算机信息系统中发生的案件，应当在规定时间内向当地（县）级及以上公安机关报告，并接受公安机关对网络系统有害数据防治工作的监督、检查和指导。



*3.4 网络安全管理原则及制度

制定相关人员岗位责任制，制定严格的管理制度、纪律，执行管理和职责分工的原则，不准串岗、兼岗，严禁程序设计师同时兼任系统操作员，严格禁止系统管理员、终端操作员和系统设计人员混岗和作业等。网络安全管理专职人员具体负责本系统区域内网络安全策略的实施，保证网络安全策略长期有效：负责网络系统软硬件的安装维护、日常操作监视、应急安全措施的恢复和风险分析等；负责整个系统的安全，对整个系统的授权、修改、特权、口令、违章报告、报警记录处理、控制台日志审阅负责，遇到重大问题不能解决时要及时向主管领导报告。网络安全审计人员监视系统运行情况，收集对系统资源的各种非法访问事件，并对非法事件记录、分析和处理，及时将审计事件及时上报主管部门。

保安人员负责非技术性常规安全工作，如系统场所的警卫、办公安全、出入门验证等。



*3.4 网络安全管理原则及制度

2. 健全网络安全管理制度

网络安全管理制度应当建立健全和完善，并认真贯彻落实。常用的网络安全管理制度主要包括以下 7 个方面：

1) **网络系统运行维护管理制度**。包括设备管理维护制度、软件维护制度、用户管理制度、密钥管理制度、出入门卫值班制度、各种操作规程及守则、各种行政领导部门定期检查或监督制度。机要重地的机房应规定双人进出及不准单人在机房操作计算机的制度。机房门加双锁，保证两把钥匙同时使用才能打开机房。信息处理机要专机专用，不允许兼作其他用途。终端操作员因故离开必须退出登录界面，避免其他人员非法使用。

2) **主机处理控制管理制度**。包括编制及控制数据处理流程、程序软件和数据的管理、拷贝移植和存储介质的管理、文件档案日志的标准化和通信网络系统的管理。

3) **文档资料管理制度**。必须妥善保管和严格控制各种凭证、单据、账簿、报表和文字资料，交叉复核记账，相关人员所掌握的资料要与其职责一致，如终端操作员只能阅读终端操作规程、手册，只有系统管理员才能使用系统手册。



*3.4 网络安全管理原则及制度

3.4.2 网络安全管理机构 and 制度

4) 建立健全操作及管理人員的管理制度。主要包括：① 指定使用和操作设备或服务器，明确工作职责、权限和范围。② 程序员、系统管理员、操作员岗位分离且不混岗。③ 禁止在系统运行的机器上做与工作无关的操作。④ 不越权运行程序，不应查阅无关参数。⑤ 对于偶尔出现的操作异常应立即报告。⑥ 建立和完善工程技术人员的管理制度。⑦ 当相关人员调离时，应采取相应的安全管理措施。如人员调离时马上收回钥匙、移交工作、更换口令、取消账号，并向被调离的工作人员申明其保密义务。

5) 机房安全管理规章制度。建立健全的机房管理规章制度，经常对有关人员进行安全 教育与培训，定期或随机进行安全检查。机房管理规章制度主要包括：机房门卫管理、机房 安全、机房卫生、机房操作管理等。

6) 其他的重要管理制度。主要包括：系统软件与应用软件管理制度、数据管理制度、密码口令管理制度、网络通信安全管理制度、病毒的防治管理制度、实行安全等级保护制 度、实行网络电子公告系统的用户登记和信息管理制度、对外交流维护管理制度等。

*3.4 网络安全管理原则及制度

3.4.2 网络安全管理机构 and 制度

7) **风险分析及安全培训制度**。主要包括：① 定期进行风险分析，制定意外灾难应急恢复计划和方案，如关键技术人员的多种络方法、备份数据的取得、系统重建的组织。② 建立安全考核培训制度。除了对关键岗位的人员和新员工进行考核之外，还要定期进行网络安全方面的法律教育、职业道德教育和安全技术更新等方面的教育培训。对于从事涉及国家安全、军事机密、财政金融或人事档案等重要信息的工作人员更要重视安全教育，并挑选可靠、素质好的人员担任。

3. 坚持合作交流制度

网络运营商是网络服务的提供者，有维护互联网安全的责任，应发挥互联网积极、正面的作用。各级政府也有责任为企业和消费者创造一个**共享、安全**的网络环境。同时也需要行业组织、企业和各利益相关方的共同努力。因此，应当大力加强与相关业务往来单位和安全机构的合作与交流，密切配合共同维护网络安全，及时获得必要的安全管理信息和技术支持更新。国内外也应当进一步加强交流与合作，拓宽网络安全国际合作渠道，建立政府、网络安全机构、行业组织及企业之间多层次、多渠道、齐抓共管的合作机制。

3.5 本章小结

网络安全管理保障体系与安全技术的紧密结合至关重要。本章简要地介绍网络安全管理与保障体系和网络安全管理的基本过程。网络安全保障包括：信息安全策略、信息安全管理、信息安全运作和信息安全技术，其中，管理是企业管理行为，主要包括安全意识、组织结构和审计监督；运作是日常管理的行为（包括运作流程和对象管理）；技术是信息系统的行为（包括安全服务和安全基础设施）。网络安全是在企业管理机制下，通过运作机制借助技术手段实现的。“七分管理，三分技术，运作贯穿始终”，**管理是关键，技术是保障**，其中的网络安全技术包括网络安全管理技术。

本章还概述了国外在网络安全方面的法律法规和我国网络安全方面的法律法规。介绍了国内外网络安全**评估准则和测评**有关内容，包括国外网络安全评估准则、国内安全评估通用准则、网络安全评估的目标内容和方法等。同时，概述了网络安全**策略和规划**，包括网络安全策略的制定与实施、网络安全规划基本原则；还介绍了网络安全管理的**基本原则**，以及健全安全管理机构和制度，最后，联系实际应用，概述了Web服务器的安全设置与管理实验的**实验目的、要求、内容和步骤**。

课后作业

练习与实践3

1 (1) (2) (5)

2 (1) (2) (7) (9)

作业提交：手写拍照或电子文档，保存为pdf格式，命名“学号-姓名”
班长/学委打包发我QQ（97251651）或者邮箱（jingkun@ahu.edu.cn）



3.6 实验3 统一威胁管理UTM应用

3.6 实验3 统一威胁管理UTM应用

统一威胁管理UTM（**Unified Threat Management**）平台，实际上类似一种多功能安全网关，与路由器和三层交换机不同的是，UTM不仅可以连接不同的网段，在数据通信过程中还提供了丰富的网络安全管理功能。

1. 实验目的

- 1) 掌握应用UTM的主要功能、设置与管理方法和过程。
- 2) 提高利用UTM进行网络安全管理、分析和解决问题的能力。
- 3) 促进以后更好从事相关网络安全管理工作奠定重要的基础。

2. 实验要求及方法

通过对**UTM**平台的功能、设置与管理方法和过程的实验，应先做好实验的准备工作,实验时注意掌握操作界面、实验内容、实验方法和实验步骤，重点是**UTM**功能、设置与管理方法和实验过程中的具体操作要领、顺序和细节。

3.6 统一威胁管理UTM应用

3. 实验内容及步骤

(1) UTM集成的主要功能

各种UTM平台的功能略有差异。H3C的UTM功能较全，特别是具备应用层识别用户的网络应用，控制网络中各种应用的流量，并记录用户上网行为的上网行为审计功能，相当于更高集成度的多功能安全网关。不同的UTM平台比较，如表1所示。

表1 不同的UTM平台比较

品牌 功能列表	H3C	Cisco	Juniper	Fortinet
防火墙功能	√ (H3C)	√ (Cisco)	√ (Juniper)	√ (Fortinet)
VPN功能	√ (H3C)	√ (Cisco)	√ (Juniper)	√ (Fortinet)
防病毒功能	√ (卡巴斯基)	√ (趋势科技)	√ (卡巴斯基)	√ (Fortinet)
防垃圾邮件功能	√ (Commtouch)	√ (趋势科技)	√ (赛门铁克)	√ (Fortinet)
网站过滤功能	√ (Secure Computing)	√ (WebSense)	√ (WebSense; SurControl)	○ (无升级服务)
防入侵功能	√ (H3C)	√ (Cisco)	√ (Juniper)	○ (未知)
应用层流量识别和控制	√ (H3C)	×	×	×
用户上网行为审计	√ (H3C)	×	×	×

UTM集成软件的主要功能包括：访问控制功能、防火墙功能、VPN功能、入侵防御系统功能、病毒过滤、网站及URL过滤、流量管理控制、网络行为审计等功能。

3.6 统一威胁管理UTM应用

(2) 操作步骤及方法

经过登录并简单配置，即可直接管理UTM平台。

1) 利用用户名密码登录：H3C 设置管理PC 的具体IP 地址之后，利用用户名和密码可以打开Web 网络管理用户登录界面。

2) 通过“设备概览”及“配置向导”等，可以进行防火墙等Web 配置，主要的管理操作首页界面如图3-11 所示。

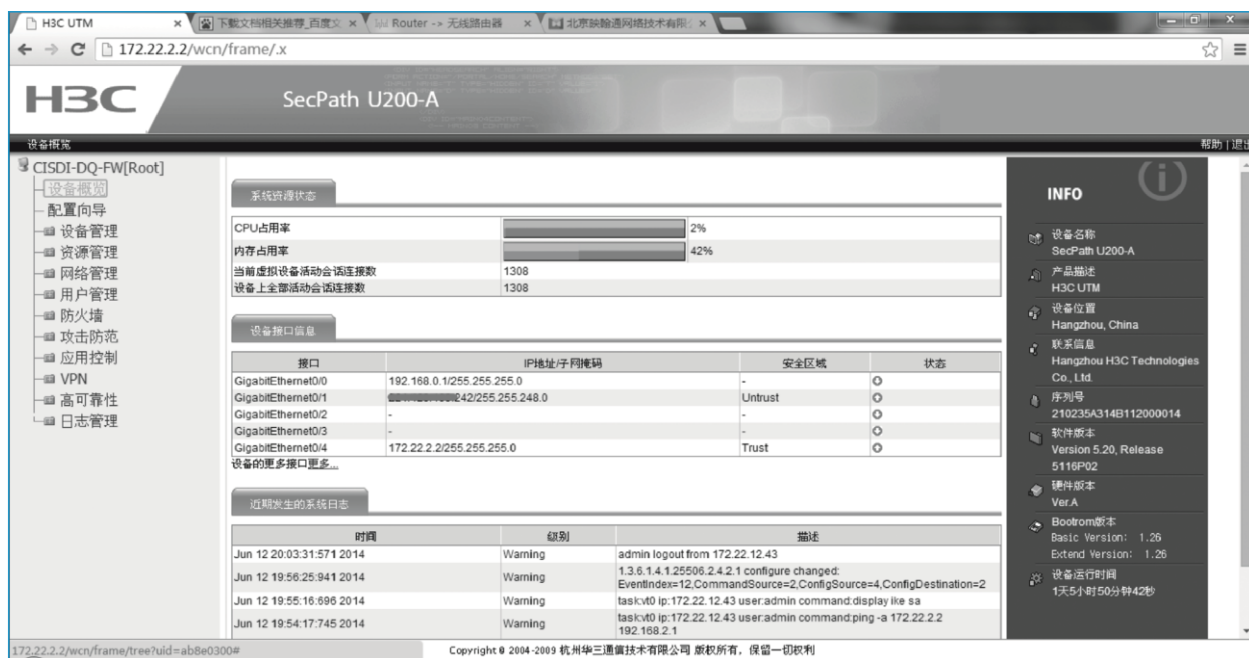


图3-11 通过“设备概览”进行界面配置

3.6 统一威胁管理UTM应用

通常，防火墙的配置方法为：

- 1) 只要设置管理PC的网卡地址，连接g0/0/0端口，就可从此进入Web管理界面。
 - 2) 配置外网端口地址，将外网端口加入安全域，如图3-12所示。
 - 3) 配置通过防火墙的访问控制策略，如图3-13 所示。
- 在防火墙设置完成之后，就可以直接登录上网。

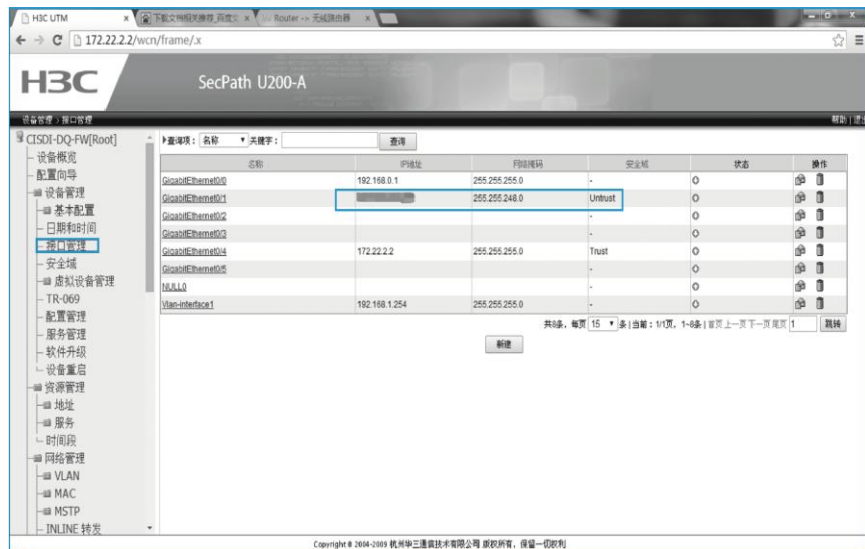


图3-12 配置外网端口地址



图3-13 配置通过防火墙的访问控制策略

3.6 统一威胁管理UTM应用

流量定义和策略设定。激活高级功能，然后“设置自动升级”，并依次完成：定义全部流量、设定全部策略、应用全部策略。可以设置防范病毒等5大功能，还可管控网络的各种流量、用户应用流量及统计情况。

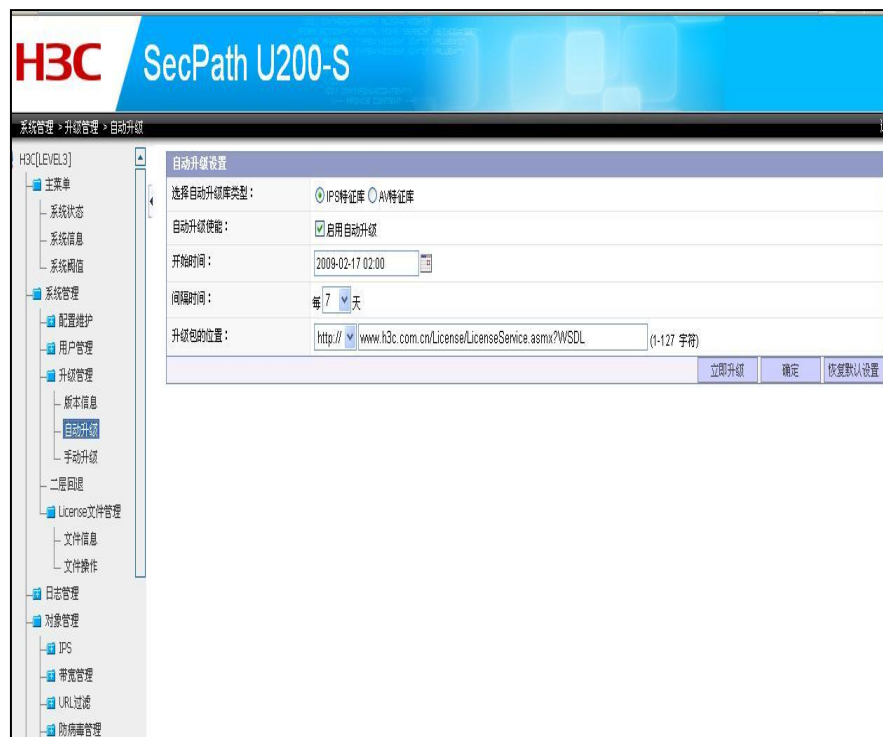


图3-26 流量定义和策略设定



图3-27 管控及统计网络流量

“十三五”国家重点出版规划
项目,上海市高校优秀教材奖

上海市高校精品课程特色教材
上海市高校优质在线课程教材

网络安全技术及应用

(第4版. 微课版立体化)



诚挚谢意!



NO:20100223113850688103